

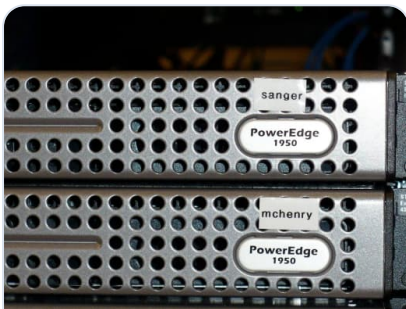
SÉCURITÉ DES APPLICATIONS WEB

Guide du TP 5 : comparer la matrice de droits, les objets et les sorties réseau

TP 5 · Contrôle d'accès, API et SSRF

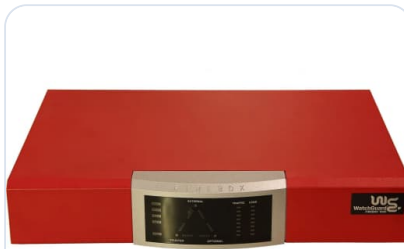


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Serveur

Fournit fichiers, messagerie ou site web aux autres



Pare-feu (firewall)

Filtre le trafic entre deux zones selon des règles

Photos issues de Wikimedia Commons : Serveur, Florence Devouard, CC BY-SA 4.0 · Pare-feu (firewall), Jakez, CC BY-SA 3.0.

CADRE ET LIMITES

- ◆ Toutes les données de ce laboratoire sont fictives et figées.
- ◆ Tu analyses uniquement des fichiers fournis ; ne teste jamais un système réel sans autorisation écrite.
- ◆ Les exemples ci-dessous utilisent des valeurs inventées, pas celles du labo.



Méthode

- 1 Ramène chaque requête à sa route logique, par exemple « GET /api/reservations/{id} ».
- 2 Lis la matrice : si « propriétaire requis » vaut oui, compare l'utilisateur du jeton à l'identifiant du propriétaire de l'objet.
- 3 Pour une route réservée au personnel, vérifie d'abord le rôle autorisé, puis le code HTTP réellement renvoyé.
- 4 Pour une série séquentielle, trie les identifiants lus et vérifie qu'ils se suivent sans trou.
- 5 Pour un débit par minute, coupe le texte de l'horodatage à « AAAA-MM-JJTHH:MM » (ses 16 premiers caractères) puis compte par jeton. Ne convertis pas l'horodatage en date locale : le « Z » final veut dire UTC, et une conversion décalerait l'heure.
- 6 Pour le SSRF, traite comme sensibles les adresses privées, locales et de lien local, par exemple 10.0.0.0/8, 172.16.0.0/12, 192.168.0.0/16, 127.0.0.1 et 169.254.0.0/16.



Bash ou Git Bash

BASH

```
cat > demo-api.jsonl <<'EOF'
{"ts":"2026-03-10T09:00:00Z","tokenId":"tok-
demo","userId":"7101","role":"client","method":"GET","path":"/api/reservations/8801","status":200,"ownerId":"7109","bytes":1800}
{"ts":"2026-03-10T09:00:21Z","tokenId":"tok-
demo","userId":"7101","role":"client","method":"GET","path":"/api/reservations/8802","status":200,"ownerId":"7108","bytes":1810}
{"ts":"2026-03-10T09:01:01Z","tokenId":"tok-demo-
2","userId":"7200","role":"staff","method":"GET","path":"/api/staff/arrivees","status":200,"ownerId":null,"bytes":900}
EOF
mismatch_demo=$(grep -c '"path":"/api/reservations/' demo-api.jsonl)
cat > demo-sortant.log <<'EOF'
2026-03-10T09:02:00Z user=7101 route=/api/apercu?url=http%3A%2F%2F127.0.0.1%2Fdebug url=http://127.0.0.1/debug status=200
bytes=320
2026-03-10T09:03:00Z user=7101 route=/api/apercu?url=https%3A%2F%2Fcdn-demo.example%2Fbrochure.pdf url=https://cdn-
demo.example/brochure.pdf status=200 bytes=2400
EOF
local_demo=$(grep -E 'url=http://(127\.|10\.|172\.([16-9]|2[0-9]|3[0-1]))\.[192\.168\.|169\.254\.]' demo-sortant.log | wc -
l)
printf 'D mo pr te : %s lectures d'objets et %s sortie(s) vers une adresse locale ou priv e.\n' "$mismatch_demo"
"$local_demo"
```

Commande longue, coup e par la mise en page : copie-la en une seule ligne ou utilise la version texte indiqu e en fin de document.



PowerShell 5.1

Les fichiers du labo sont en UTF-8 : avec Windows PowerShell 5.1, garde l'option `-Encoding UTF8` de `Get-Content`, sinon les accents s'affichent mal.

POWERSHELL

```
@'
{"ts":"2026-03-10T09:00:00Z","tokenId":"tok-
demo","userId":"7101","role":"client","method":"GET","path":"/api/reservations/8801","status":200,"ownerId":"7109","bytes":1800}
{"ts":"2026-03-10T09:00:21Z","tokenId":"tok-
demo","userId":"7101","role":"client","method":"GET","path":"/api/reservations/8802","status":200,"ownerId":"7108","bytes":1810}
{"ts":"2026-03-10T09:01:01Z","tokenId":"tok-demo-
2","userId":"7200","role":"staff","method":"GET","path":"/api/staff/arrivees","status":200,"ownerId":null,"bytes":900}
'@ | Set-Content -Encoding UTF8 demo-api.jsonl
$demoApi = Get-Content -Encoding UTF8 "demo-api.jsonl"
$mismatchDemo = @($demoApi | Where-Object { $_ -match '"path":"/api/reservations/' }).Count
@'
2026-03-10T09:02:00Z user=7101 route=/api/apercu?url=http%3A%2F%2F127.0.0.1%2Fdebug url=http://127.0.0.1/debug status=200
bytes=320
2026-03-10T09:03:00Z user=7101 route=/api/apercu?url=https%3A%2F%2Fcdn-demo.example%2Fbrochure.pdf url=https://cdn-
demo.example/brochure.pdf status=200 bytes=2400
'@ | Set-Content -Encoding UTF8 demo-sortant.log
$localDemo = @(Get-Content -Encoding UTF8 "demo-sortant.log" | Where-Object { $_ -match 'url=http://(127\.|10\.|172\.([16-
9]|2[0-9]|3[0-1]))\.[192\.168\.|169\.254\.]' }).Count
"D mo pr te : $mismatchDemo lectures d'objets et $localDemo sortie(s) vers une adresse locale ou priv e."
```

Commande longue, coup e par la mise en page : copie-la en une seule ligne ou utilise la version texte indiqu e en fin de document.



Visionneuse du site

Dans la visionneuse, filtre d'abord sur des mots g n riques comme `«/api/reservations/»`, `«/api/staff/»`, `«169.254.169.254»`, `«127.0.0.1»` ou `«status=200»`, puis relis chaque ligne compl te avant de conclure.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).